

New Coworker

Information Security Policy

Document owner: Engineering Leadership

Version: 1.1

Effective: July 15, 2026

Review cycle: Annual

1. Purpose and Scope

This policy defines the security requirements governing the New Coworker platform (newcoworker.com), including the **New Coworker OAuth** Zoom Marketplace application. It applies to all production systems, source code, third-party integrations, and personnel with access to production data or infrastructure.

2. Data Classification and Handling

Class	Examples	Required controls
Secrets & credentials	OAuth access/refresh tokens (Zoom, Google, Microsoft), API keys	AES-256-GCM encryption at rest with a dedicated key held only in the server environment; never logged; never exposed to the browser; masked in all dashboard/API responses
Customer data	Business records, contacts, messages, calendar events	Postgres row-level security (RLS) on every tenant table; service-role access confined to server-side code; TLS 1.2+ in transit
Public data	Marketing site content	Integrity via standard release controls

3. Access Control

- Production database access is deny-by-default: sensitive tables enable RLS with **no** anon/authenticated policies, so only audited server-side service-role code can read them.
- Third-party OAuth grants are requested with the minimum scopes required for the advertised feature (for Zoom: meeting read/write on the connected user only).
- Repository access is limited to authorized engineers; branch protection requires all status checks and code review before merge to `main`.
- Secrets are stored in the deployment platform's encrypted environment configuration, never in source control. GitGuardian secret scanning runs on every pull request to prevent accidental credential commits.

4. Encryption Standards

- In transit:** all endpoints are HTTPS-only and negotiate TLS 1.2 or higher. HSTS is enforced with `max-age=63072000; includeSubDomains; preload`.
- At rest:** integration secrets and OAuth token pairs are envelope-encrypted with AES-256-GCM before storage; the underlying database volumes are additionally encrypted by the hosting provider.
- OAuth state:** authorization flows use HMAC-signed, expiring state parameters to prevent CSRF and flow-binding attacks. Refresh-token rotation is honored with optimistic-concurrency persistence so a token is never reused after rotation.

5. Application Security Headers

Every production response carries a hardened baseline: `Strict-Transport-Security`, `X-Content-Type-Options: nosniff`, `X-Frame-Options: DENY`, `Referrer-Policy: strict-origin-when-cross-origin`, a restrictive `Permissions-Policy`, and `Content-Security-Policy: frame-ancestors 'none'; base-uri 'self'; object-src 'none'`.

6. Secure Development

- All changes ship through pull requests gated by: static analysis (CodeQL SAST), lint, strict TypeScript type-checking, the full automated test suite with a **100% statement/branch/function/line coverage requirement**, dependency audit (high severity and above fails the build), integration tests against a production-parity database, and automated AI code review with every finding resolved before merge.
- A deployment gate blocks production deploys until every check on the release commit is green and every review conversation is resolved.

7. Incident Response Alignment

Suspected security incidents follow the Vulnerability Management Procedures (companion document): triage within one business day, credential rotation and revocation ahead of root-cause analysis, and customer notification where data exposure is confirmed. Zoom-related incidents additionally trigger deauthorization of affected connections via token revocation at Zoom's `/oauth/revoke` endpoint.

8. Enforcement and Review

Exceptions to this policy require written approval from the document owner and a compensating control. The policy is reviewed at least annually and after any material architecture change.